Day 10 Task — OSINT Challenge (BrightLeaf Organics)

Cyber Security Internship · Module 2: Know Your Battlefield · Fictional Target Exercise

Step 1 — Build the Attacker's Profile

What the attacker learns	Your answer (from the clues)
Email address format	firstname.lastname@brightleaf-organics.example (with general inquiries at careers@brightleaf-organics.example; PDF metadata also reveals username format r.kumar).
Who handles money / payments?	Meera Shah (Finance Manager), who reports directly to CEO Arjun Rao and recently led the company's transition to Sage accounting.
Who is AWAY and when? (two people)	1) Arjun Rao (CEO): Away all next week attending the Dubai food expo. 2) Meera Shah (Finance Manager): Away on maternity leave starting from the 20th.
What systems/tools does the company use?	Microsoft 365, Fortinet firewalls, Sage accounting (newly implemented this quarter), and Microsoft Office 2016.
Who is the newest, least-trained target?	Dev, the new intern who is currently in his first week at the company.
One personal hook an attacker could use	CEO Arjun Rao is away at the Dubai food expo all next week while Finance Manager Meera Shah is going on maternity leave from the 20th (plus a sticky note is visible on Meera's monitor in her public Instagram photo).

Step 2 — Design the Spear-Phish (Written Exercise Only)

Element	Your answer
Who is it FROM (impersonated)?	Arjun Rao, CEO — sent from a lookalike domain: arjun.rao@brightleaf-organic.example (missing the "s" in organics).
Who is it TO, and why them?	Dev (the new intern, dev@brightleaf-organics.example). As a first-week intern, Dev is eager to impress the CEO, unfamiliar with internal accounting/payment workflows, and easily pressured while Meera Shah is away on maternity leave.
Subject line	Urgent: Dubai Food Expo booth payment – need quick help while Meera is on leave
The hook (why it's believable)	References real, verifiable public details: Arjun's trip to the Dubai food expo, Meera Shah's maternity leave starting the 20th, and the recent move to Sage accounting. This explains why the CEO cannot reach Finance normally and needs quick help.
The ask (what the attacker wants)	Wants Dev to initiate an urgent external payment / purchase prepaid client vouchers (or provide portal access) for an "expo vendor deadline" before 3:00 PM while keeping the request confidential.

Simulated Spear-Phishing Email Body (Fictional Exercise):

Hi Dev,

Welcome aboard! Since Meera is out on maternity leave and I'm tied up in meetings at the Dubai food expo all week, I need your quick help handling an urgent Sage vendor invoice for our expo booth before 3:00 PM today. Please reply to this email as soon as you see it so I can send over the transfer instructions—keep this between us for now while I get it sorted.

Best,
Arjun Rao | CEO, BrightLeaf Organics

Step 3 — Spot the Red Flags

#	Red flag in the email
1	Lookalike Sender Domain: The sender address uses "brightleaf-organic.example" (missing the "s") instead of the real company domain "brightleaf-organics.example".
2	Artificial Urgency & Time Pressure: Demands action "before 3:00 PM today" to rush the intern into acting before verifying the request.
3	Secrecy & Bypassing Controls: Instructing a new intern to "keep this between us" and bypass standard Finance/Sage approval workflows is a classic Business Email Compromise (BEC) warning sign.
4	Unusual Authority Mismatch: A CEO would never ask a first-week intern to process urgent vendor payments instead of an authorized finance backup or senior manager.
5	Informal Out-of-Process Payment Request: Asking to coordinate invoice/transfer details via casual email replies rather than through official Sage accounting workflows.

Step 4 — Write the Defence (Blue-Team Recommendations)

#	Recommendation
1	Enforce Out-of-Band Payment Verification (Process): Require dual-approval in Sage and verbal verification via a known internal phone number (never by replying to the email) before releasing any funds or changing vendor bank details, especially while executives are traveling.
2	Configure Email Authentication & External Banners (Technical): Enforce strict SPF, DKIM, and DMARC (p=reject) records on brightleaf-organics.example, register lookalike domains, and display prominent "External Sender" warning banners on incoming emails.
3	Establish Social Media & OPSEC Posting Rules (People/Policy): Instruct employees not to share live travel schedules (Dubai expo), leave dates (maternity leave starting the 20th), internal tool rollouts (Sage), or workspace photos showing monitors/sticky notes and visitor badges.
4	Mandatory Day-One Phishing & BEC Onboarding (Training): Include Business Email Compromise and executive-impersonation scenarios in day-one orientation for all new hires and interns (like Dev), emphasizing that no executive will ever ask them to bypass financial controls.
5	Scrub Document Metadata & Harden Legacy Software (Technical): Strip author usernames (r.kumar) and software tags from public website PDFs before publishing, upgrade outdated Office 2016 installations, and enforce phishing-resistant MFA on Microsoft 365, Fortinet VPN, and Sage.